QCon
全球软件开发大会

InfoQ 技术大会

企业级 Agent Infra 架构实践
安全沙箱、租户网络与身份治理

方宇晨

上汽集团 云计算中心架构师



QCon
全球软件开发大会

InfoQ 技术大会

目录

01 Agent 带来的基础设施挑战

02 运行时与安全沙箱

03 租户网络与访问边界

04 Agent身份认证

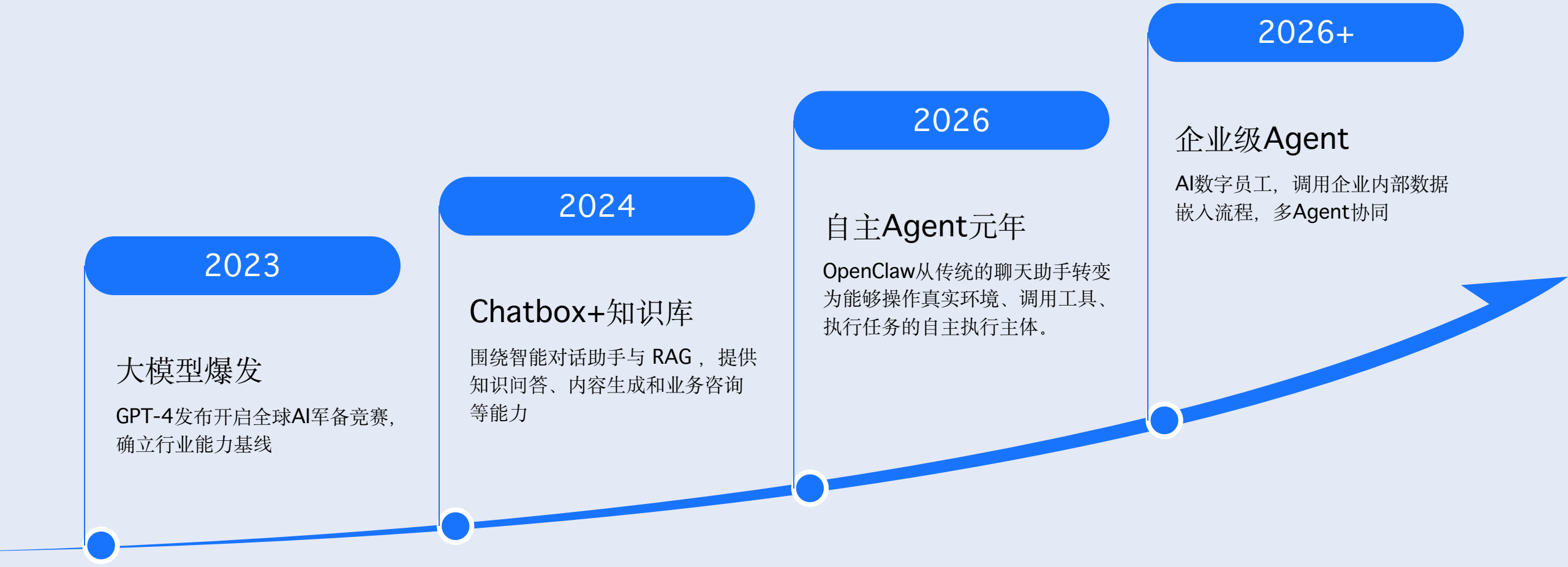
05 七层流量管理与细粒度授权

06 案例，问题与展望

01

Agent 带来的基础设施挑战

从大模型到企业级Agent



Agent 的自主执行扩大了风险边界

部署的Agent无法保证安全可靠性，存在破坏运行时环境的可能性

不可信代码

Agent有很强的自主性，无法提前预知当前任务会调用的网络请求

任意调用外部网络

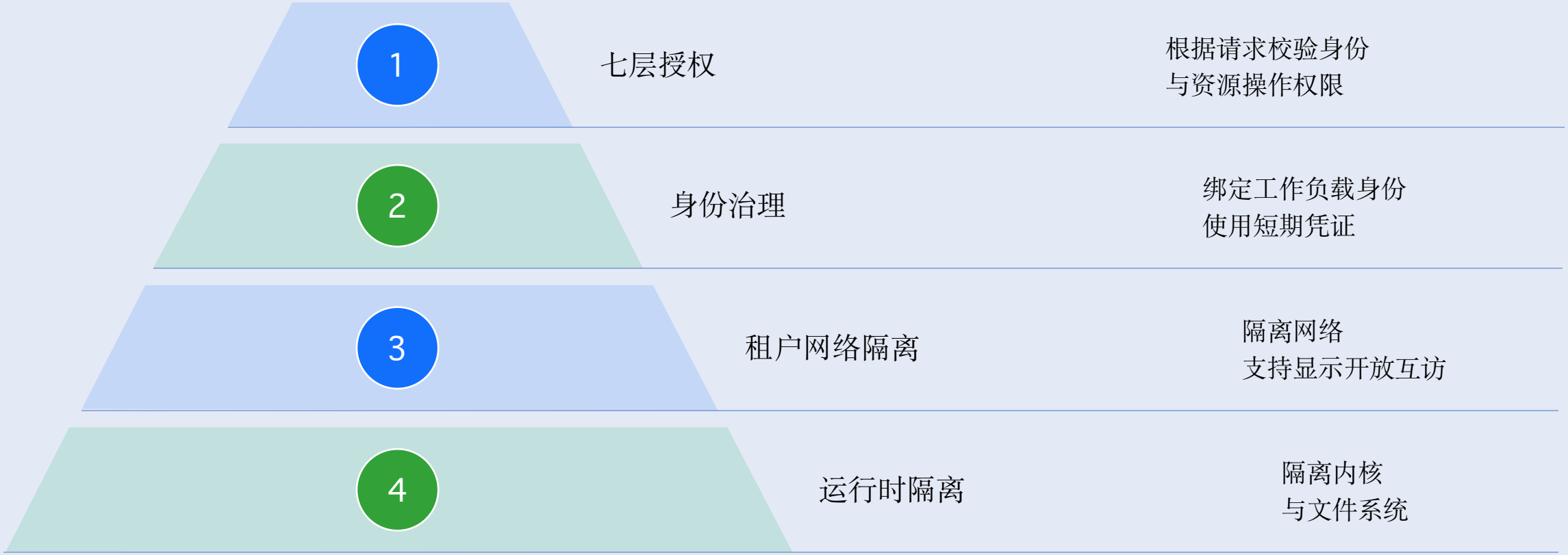
Agent与平台，Agent与Agent之间如果没有统一身份，难以实现身份互认与可信通信

缺乏统一的身份

Agent 具备自主调用的能力，超出预期权限范围访问敏感数据、调用高危 API接口

未授权访问

四层边界共同约束 Agent 的行为



02

运行时与安全沙箱

运行时的需要提供的能力

生命周期管理

统一创建、回收、挂起与恢复流程，区分进程健康、应用就绪和任务完成。



不可信代码隔离

提供独立内核边界，降低代码执行对宿主机的影响。

独立工作空间

按任务选择临时盘或持久卷，支持快照、恢复与数据清理。

短期身份凭证

向工作负载注入短期 Token，支持自定义轮换时间

K8S Agent Sandbox 项目

- 基于Pod的生命周期管理
- 支持缓存池分配和回收

基于现有K8S能力

- 通过 RuntimeClass 选择 Kata 隔离运行时

内核隔离

- 持久数据使用 PVC
- 临时数据使用 emptyDir
- 卷快照基于CSI能力

工作空间与存储

- 支持K8S SA
- 注入可轮换 SA Token
- 设置轮换期限

身份凭证投射

03

租户网络与访问边界

Agent Infra需要多租户隔离

为了资源利用率，集群会被共享

集群资源共享

公有云的多租户Agent Infra依赖VPC网络

类公有云VPC能力

平台基于K8s构建，K8s网络能力需要保留

K8s的标准网络

防火墙和遗留系统依赖IP来做访问控制

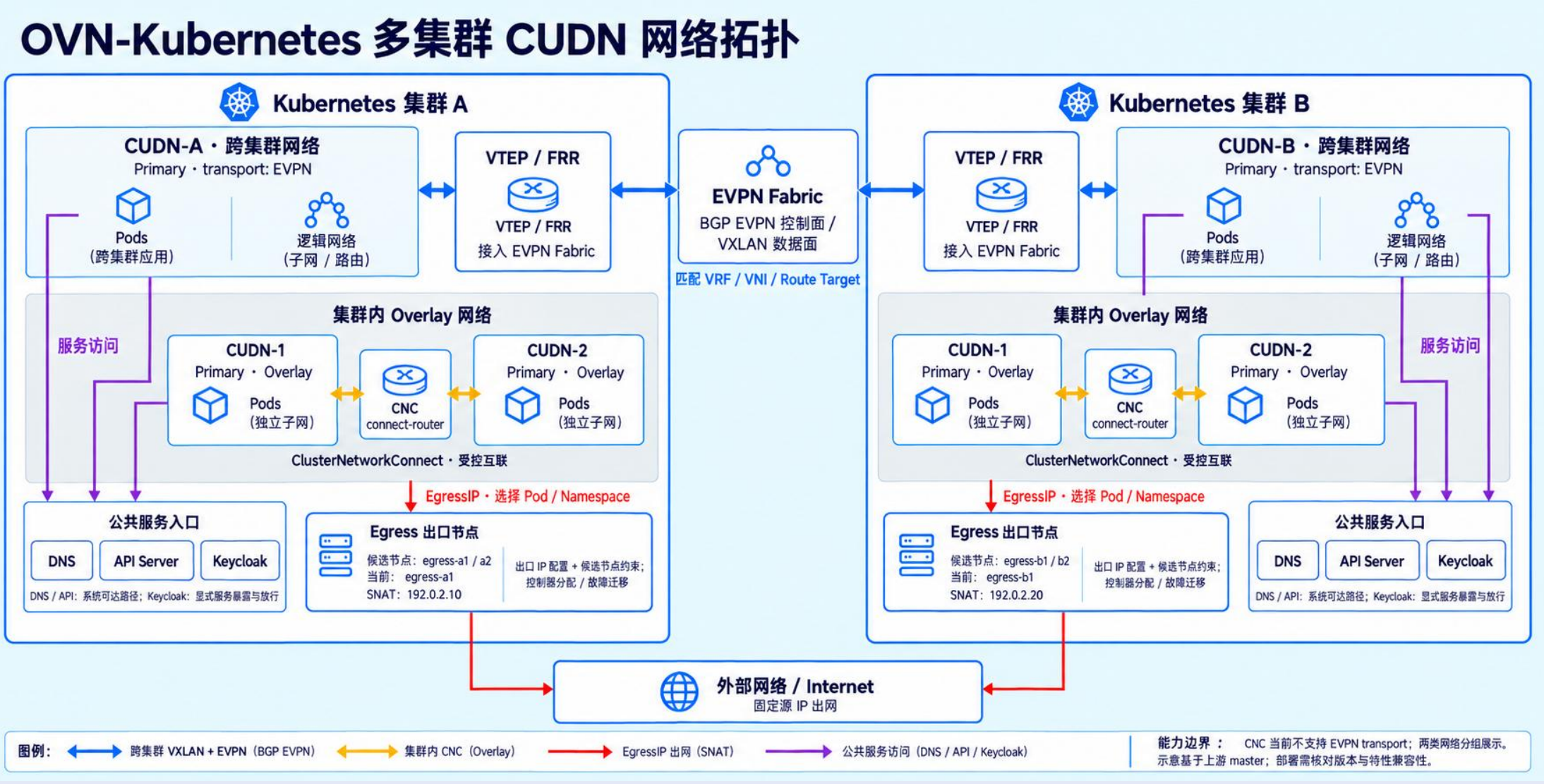
可控的外部出口

OVN-Kubernetes 建立多租户网络

CUDN= ClusterUserDefinedNetwork, CNC = ClusterNetworkConnect

1	2	3	4	5
CUDN 网络域	受控网络互联	固定出口身份	服务与公共访问	跨集群互联
◘ 跨 Namespace 定义租户网络 ◘ 保留 LoadBalancer Service, NetworkPolicy和健康检查等基础能力	◘ 使用 CNC 显式连接选定的租户网络 ◘ 支持可控的互联	◘ 通过 EgressIP 规划出口地址与承载节点 ◘ 访问外部白名单	支撑可控的与K8S默认网络的互通 DNS、API Server 等	结合 EVPN / VXLAN 打通到其他集群或者物理网络

拓扑示例：租户网络隔离，公共服务受控访问



04

Agent身份认证

构建Agent统一身份管理

每个组织或者个人的Agent数量会膨胀

Agent数量多

Agent的生命周期从长期到几分钟

Agent生命周期不一

Agent会调用大量的企业内部服务

调用的服务多

Token数量多，生命周期短

Token管理量大

KeyCloak Federated Kubernetes Service Account

- 使用 Projected SA Token
- 配合 Kubelet 自动轮换SA Token

短期凭证

- 绑定特定集群、命名空间
- 将 ServiceAccount 映射到 Keycloak Client

工作负载绑定

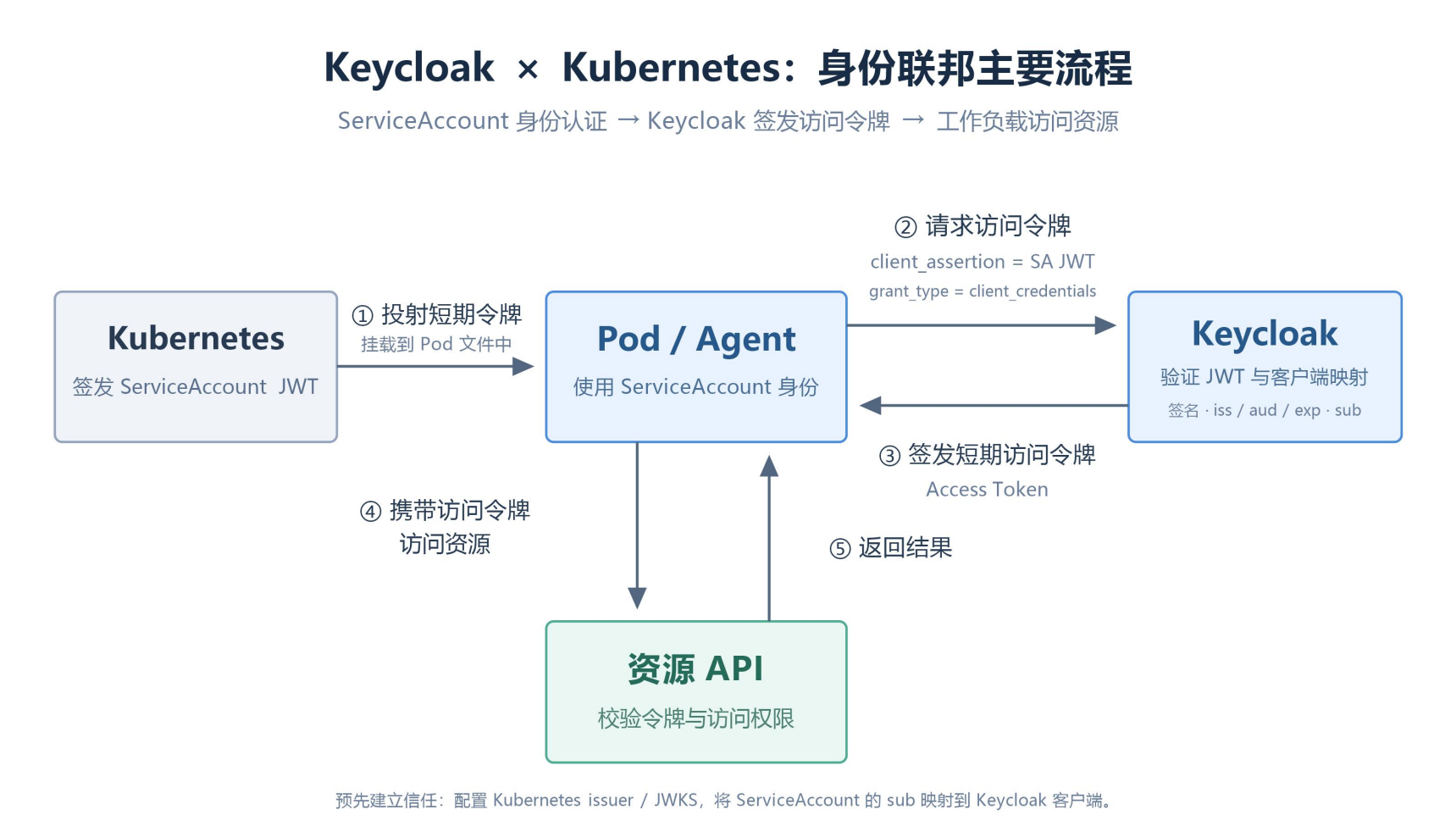
通过 Kubernetes Identity Provider 配置信任的签发方

k8S签发方信任

将 SA Token 作为身份认证提交，获取 Keycloak Access Token

标准Oauth

工作负载认证：SA Token 换取业务访问令牌



05

七层流量管理与细粒度授权

七层流量管理与细粒度授权

Agent发起的网络请求不可控，平台必须限制访问范围

限制Agent访问范围

支持对MCP，A2A和外部系统做细粒度权限控制

精细化权限控制

Agent持有外部系统的访问凭证，容易出现泄露的风险

不能持有外部凭证

HTTPS不能作为Agent避开请求内容管理的手段

HTTPS 内容透明

现有Istio治理方案的问题

CUDN网络部署Istio需适配Istiod服务发现，定制 Istiod 会增加维护成本

服务发现适配

Istio原生的Sidecar实现过重，推荐的Ambient模式与 Kata、CUDN的组合目前无法匹配

数据面选型约束

通用 HTTP 策略难以表达MCP Toolcall与A2A Task语义

工具级授权

HTTPS流量 Man In The Middle（MITM）拦截缺失

HTTPS 凭证注入

新一代7层治理方案：AgentGateway

- 支持 MCP、A2A 等协议的请求语义

面向 Agent 协议

- 统一代理HTTP/HTTPS请求
- 支持HTTPS CONNECT Proxy与MITM的动态CA签发

代理与MITM

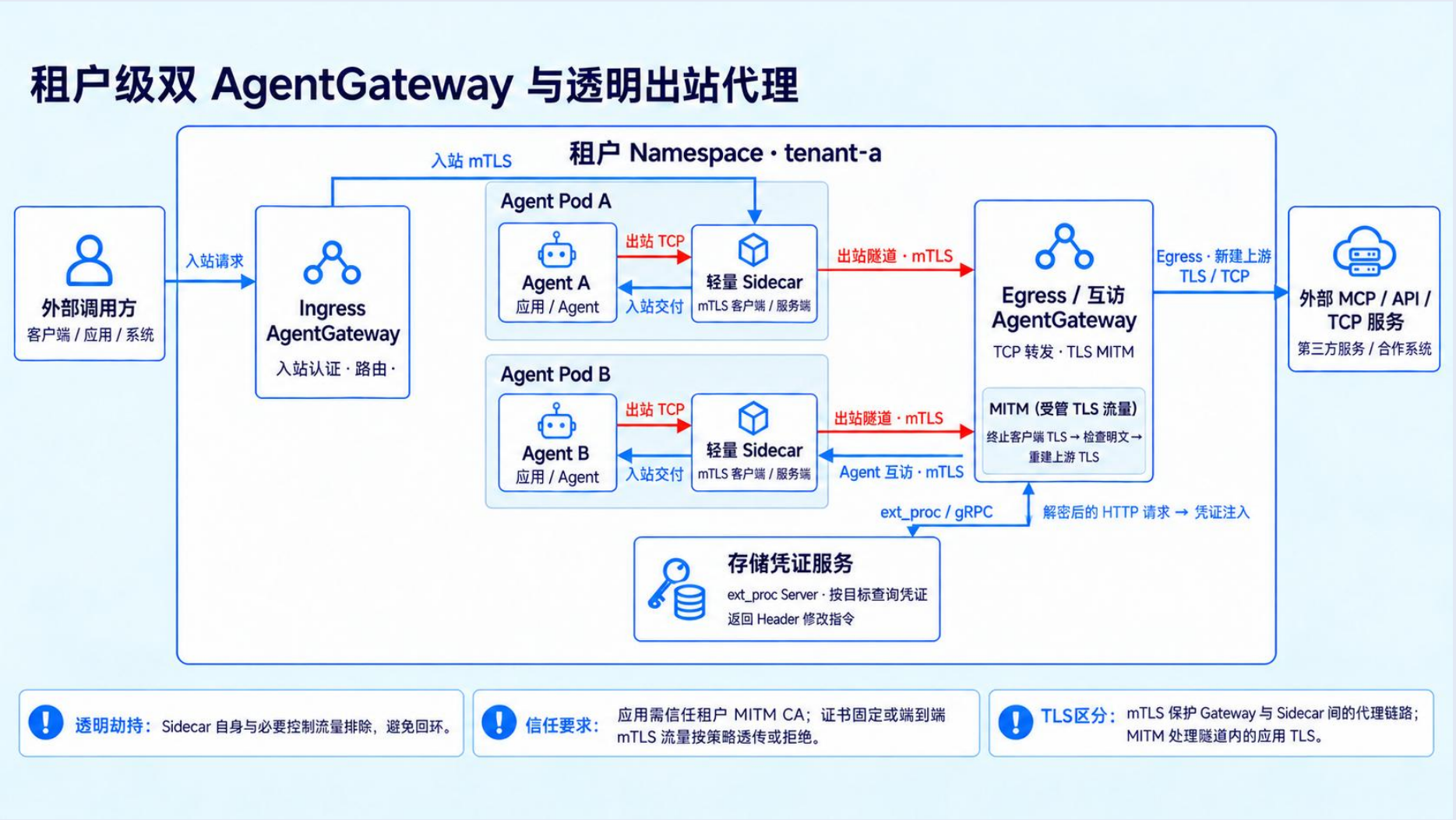
- 校验 JWT 等身份凭证
- 以 CEL 表达访问条件
- 通过 ext_authz 接入外部鉴权系统

身份与细粒度授权

- 支持配置审计日志
- 关联 Trace 和 Metrics

审计与可观测性

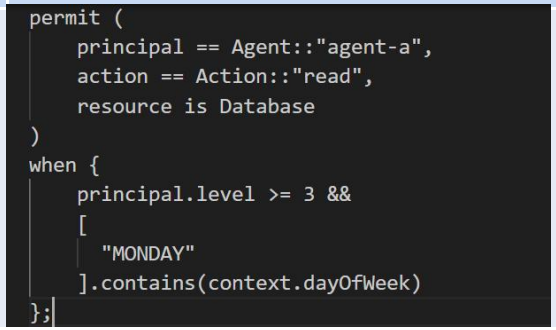
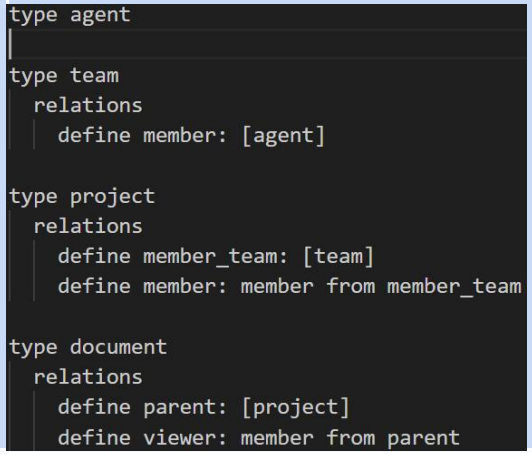
架构设计：轻量级Sidecar 代理流量，网关执行治理



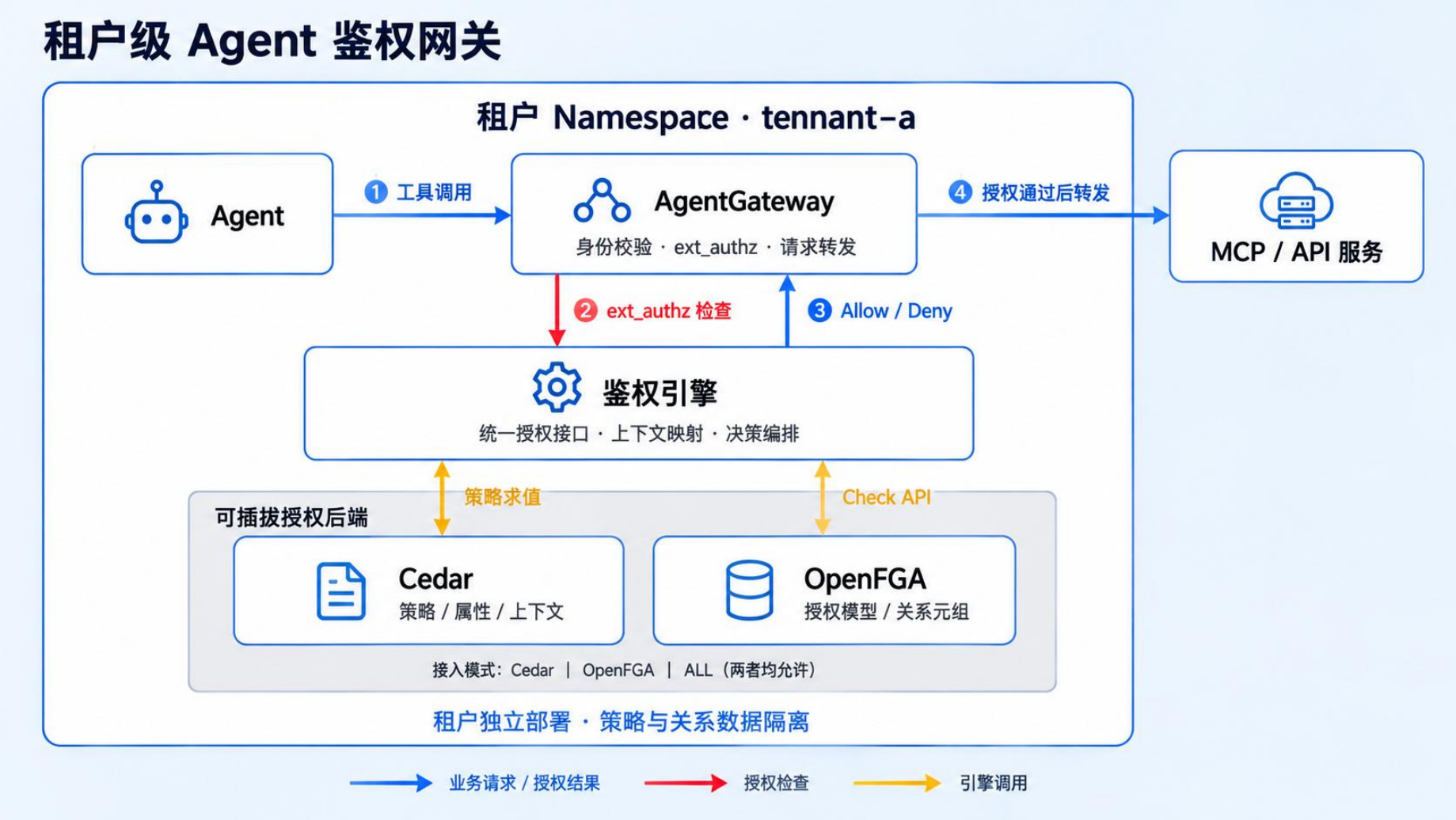
授权模型介绍

根据业务规则选择模型							
名称	类型	核心思想	权限粒度	资源继承	主要优势	主要缺点	开源框架
RBAC	基于角色的访问控制	用户拥有什么角色	通常为角色或资源类型级	通过角色继承	简单、易管理、易审计	角色爆炸、实例级授权不灵活	OpenFGA, Cedar, Open Policy Agent
ABAC	基于属性的访问控制	请求满足什么属性条件	可细化至资源实例和请求上下文	通过规则表达	灵活、上下文感知、细粒度	策略复杂、属性获取与治理成本高	Cedar, Open Policy Agent
ReBAC	基于关系的访问控制	主体与资源存在什么关系	可细化至具体资源实例	适合层级关系和权限继承	复杂关系、资源共享和授权继承	关系图建模及一致性管理很复杂	OpenFGA

授权模型示例

各类授权模型示例			
名称	授权规则示例	逻辑判断	典型场景
RBAC	role=editor 允许 document:write	Agent 有 Editor 角色，即可编辑允许范围内的文档	企业管理后台
ABAC		仅允许安全等级达到 3的 agent-a，周一读取数据库资源。	动态业务策略
ReBAC		文档所属项目的成员团队中的 Agent，拥有该文档的 viewer 权限。	有复杂关系的资源管理

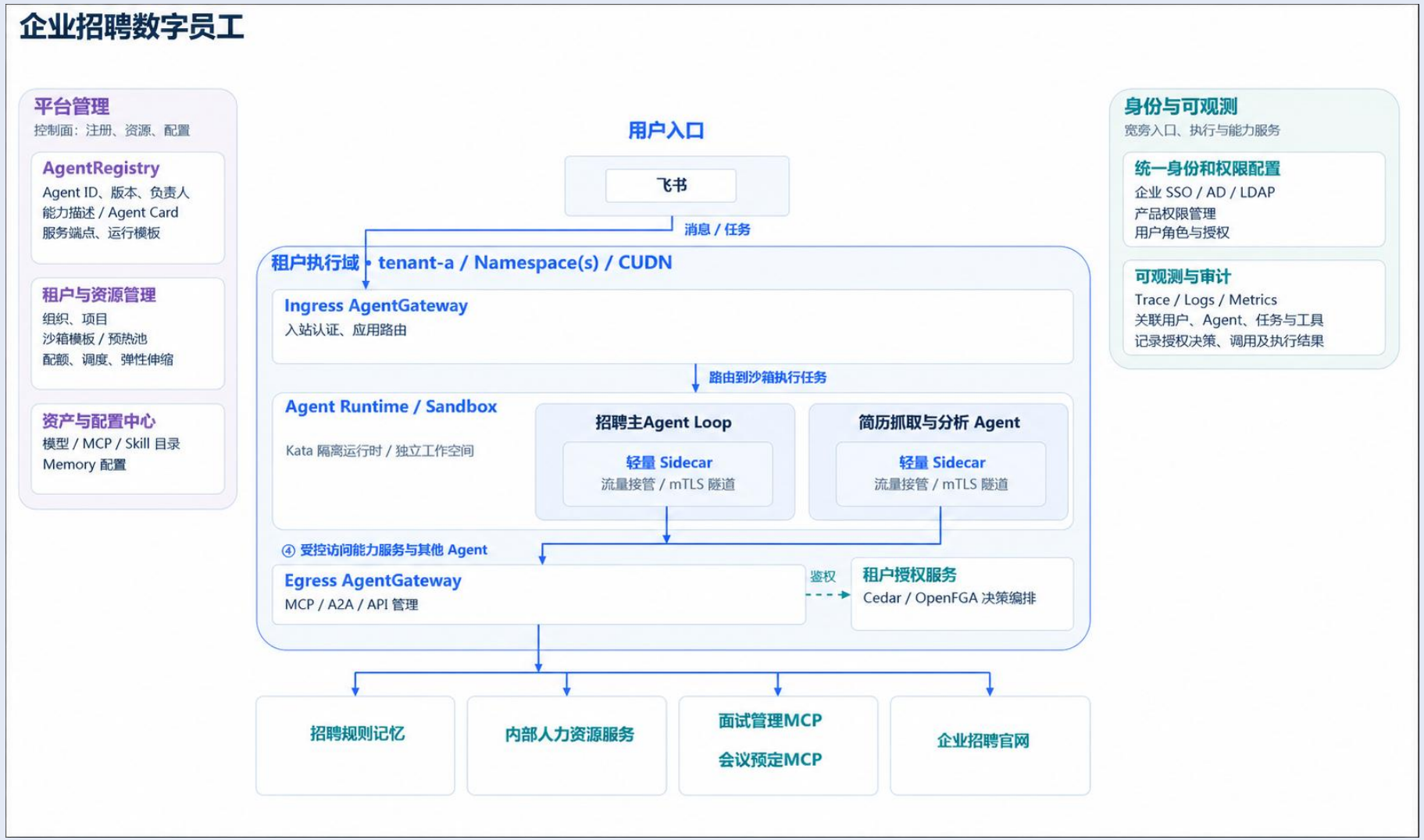
统一授权链路：网关执行，策略引擎决策



06

案例，问题与展望

案例


企业招聘数字员工
平台管理
控制面：注册、资源、配置
AgentRegistry
Agent ID、版本、负责人
能力描述 / Agent Card
服务端点、运行模板
租户与资源管理
组织、项目
沙箱模板 / 预热池
配额、调度、弹性伸缩
资产与配置中心
模型 / MCP / Skill 目录
Memory 配置
用户入口
飞书
消息 / 任务
租户执行域 • tenant-a / Namespace(s) / CUDN
Ingress AgentGateway
入站认证、应用路由
路由到沙箱执行任务
Agent Runtime / Sandbox
Kata 隔离运行时 / 独立工作空间
招聘主Agent Loop
轻量 Sidecar
流量接管 / mTLS 隧道
简历抓取与分析 Agent
轻量 Sidecar
流量接管 / mTLS 隧道
④ 受控访问能力服务与其他 Agent
Egress AgentGateway
MCP / A2A / API 管理
鉴权
租户授权服务
Cedar / OpenFGA 决策编排
招聘规则记忆
内部人力资源服务
面试管理MCP
会议预定MCP
企业招聘官网
身份与可观测
宽旁入口、执行与能力服务
统一身份和权限配置
企业 SSO / AD / LDAP
产品权限管理
用户角色与授权
可观测与审计
Trace / Logs / Metrics
关联用户、Agent、任务与工具
记录授权决策、调用及执行结果

问题：Pod 数量、空闲成本与恢复时延

每个 Agent 独占 Pod
频繁创建与回收会增加 API、调度与存储压力

控制面压力

低活跃 Agent 长期驻留
消耗内存与运行时资源

空闲资源成本

低成本恢复快照与执行状态

恢复链路成本

。

探索方向：Agent Substrate 解耦状态和执行

Actor 与 Worker 解耦

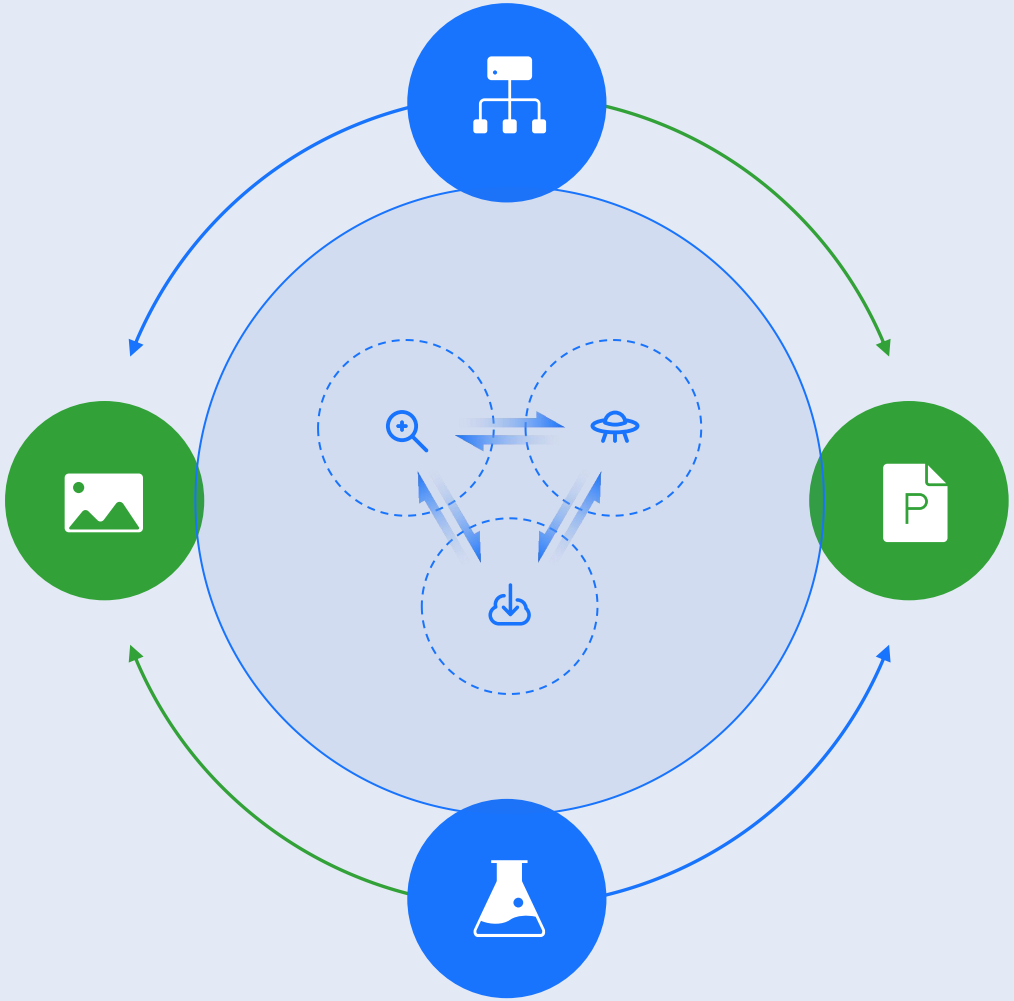
Agent 保留身份与状态，由 Worker 承载执行，减少独占 Pod

Actor 网络与隧道

通过私有 veth 与mTLS隧道访问 Actor

请求触发恢复

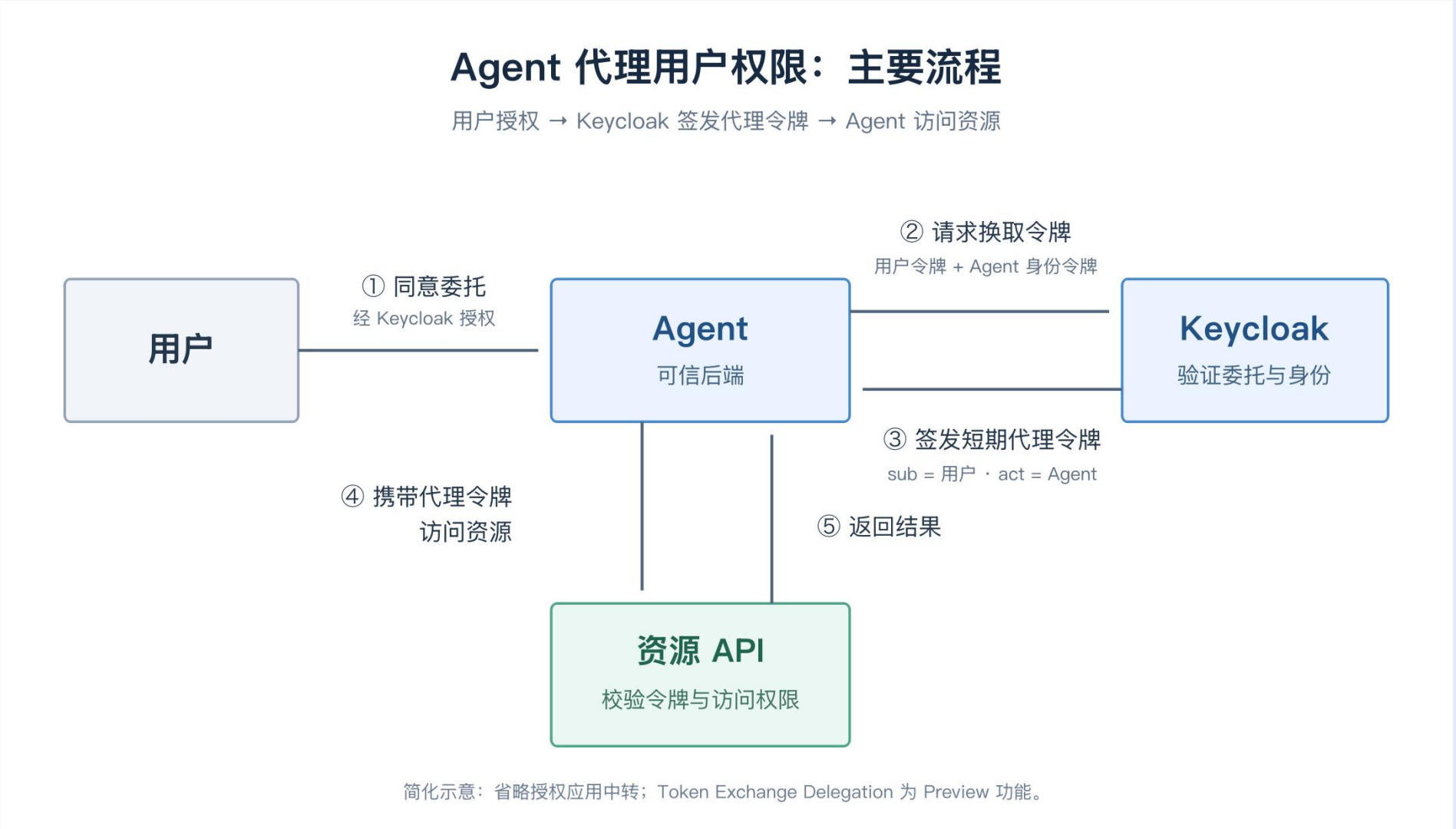
atenet-router 按转发到Actor，并且按需唤醒Actor调度到一个Pod负载



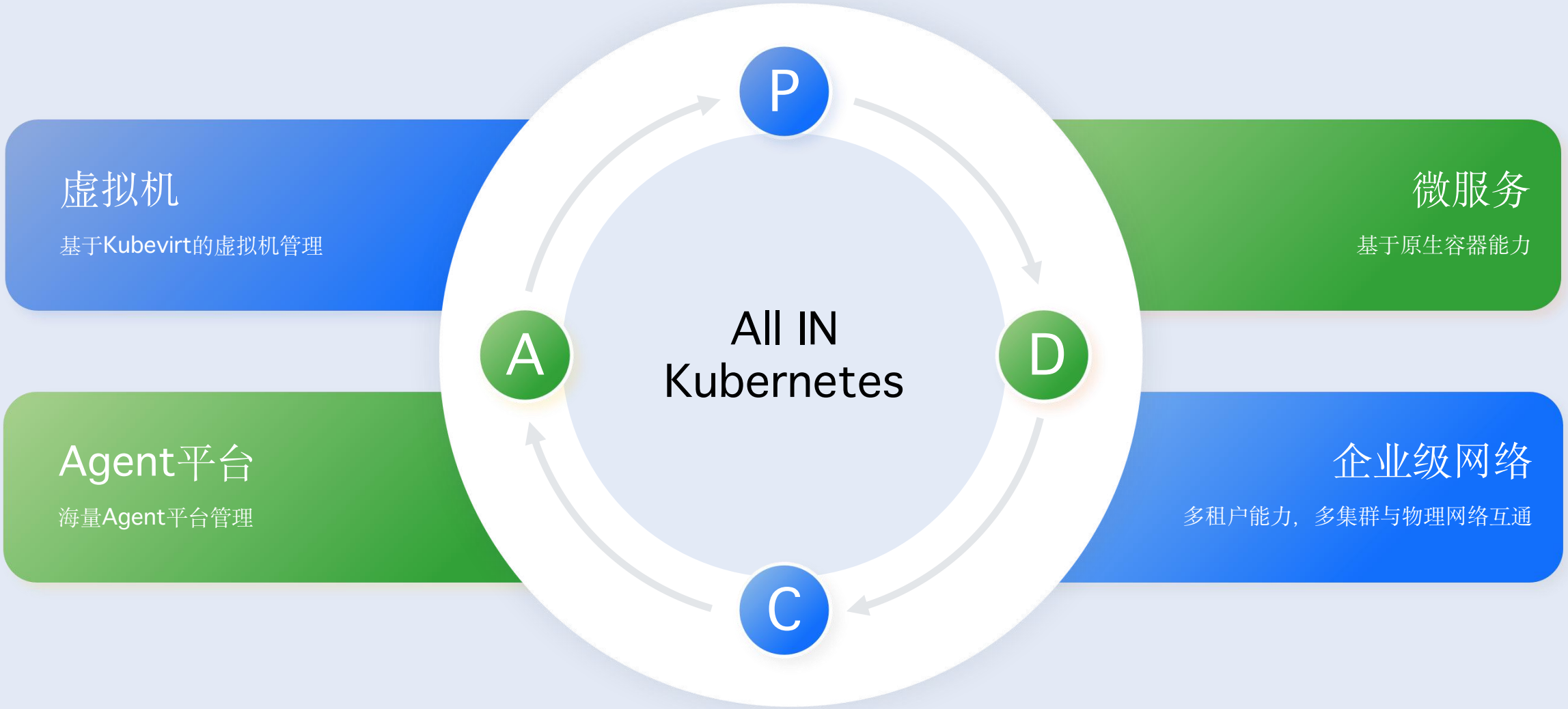
问题：Agent 何时可以代表用户操作



探索方案： KeyCloak Token Exchange Delegation



未来展望： 企业级Infra融合传统Infra与Agent Infra



AiCon 北京站

全球人工智能开发与应用大会

探索 AI 应用边界

Explore the limits of AI applications

2026 年 12 月 18–19 日 / 北京新云南皇冠假日酒店

参会咨询

专题：Post-Training Engineering | 数据、奖励与模型能力塑造



专题出品人：余瑶

飞猪 / 资深算法专家

专题：大模型推理与算力调度实践



专题出品人：范苑

阿里云 / 专有云计算产品负责人

专题：Knowledge Engineering | 让 Agent 理解企业



专题出品人：盛茂家

火山引擎 / Viking 团队技术负责人

专题：Loop & Graph Engineering



专题出品人：孙子荀

腾讯 / 腾讯高级总监

专题：AI 原生架构的演进与治理



专题出品人：刘中兵

快手 / 架构治理团队 & AI 架构演进负责人

专题：Agentic Software Engineering | 从代码生成到软件交付



专题出品人：杨杰

荣耀 / 首席 IT 技术架构师

QCon
全球软件开发大会

InfoQ 技术大会

THANKS

大模型正在重新定义软件

Large Language Model Is Redefining The Software

